Reg no :24RP02000

Module: Backend using Java

Department: ICT

Option: Information Technology

Institution: RP KARONGI COLLEGE

On 26 February 2026

19 March 2026

PHASE 7 SUBMISSION REPORT: AUTHENTICATION & SECURITY

GitHub Repository:

https://github.com/Etienne-2004/SMART-UNIVERSITY-DEVICES-AND-MATERIALS-MAINTENANCE-SYSTEM.git

1. EXECUTIVE SUMMARY

Phase 7 focused on implementing a comprehensive authentication and security system while enhancing the dashboard user interface with modern a

This phase successfully delivered:

- Secure authentication using JWT tokens
- OTP-based email verification
- Role-Based Access Control (RBAC)

The system now ensures both **high-level security** and **excellent user experience** across all roles.

2. AUTHENTICATION & SECURITY IMPLEMENTATION

2.1 JWT Security Configuration

- Secure JWT token generation with embedded user roles
- Token validation via middleware for every request
- Spring Security filters configured for API protection
- Password encryption using BCrypt

2.2 OTP Verification System

- Email-based OTP delivery using Gmail SMTP
- Secure 6-digit OTP generation
- OTP expiration set to 10 minutes
- Rate limiting to prevent abuse

2.3 Role-Based Access Control (RBAC)

Defined system roles:

- ADMIN
- STAFF
- TECHNICIAN
- CLEANER_STUDENT

Key features:

- Permission matrix for each role
- Role-specific dashboards
- Protected API endpoints

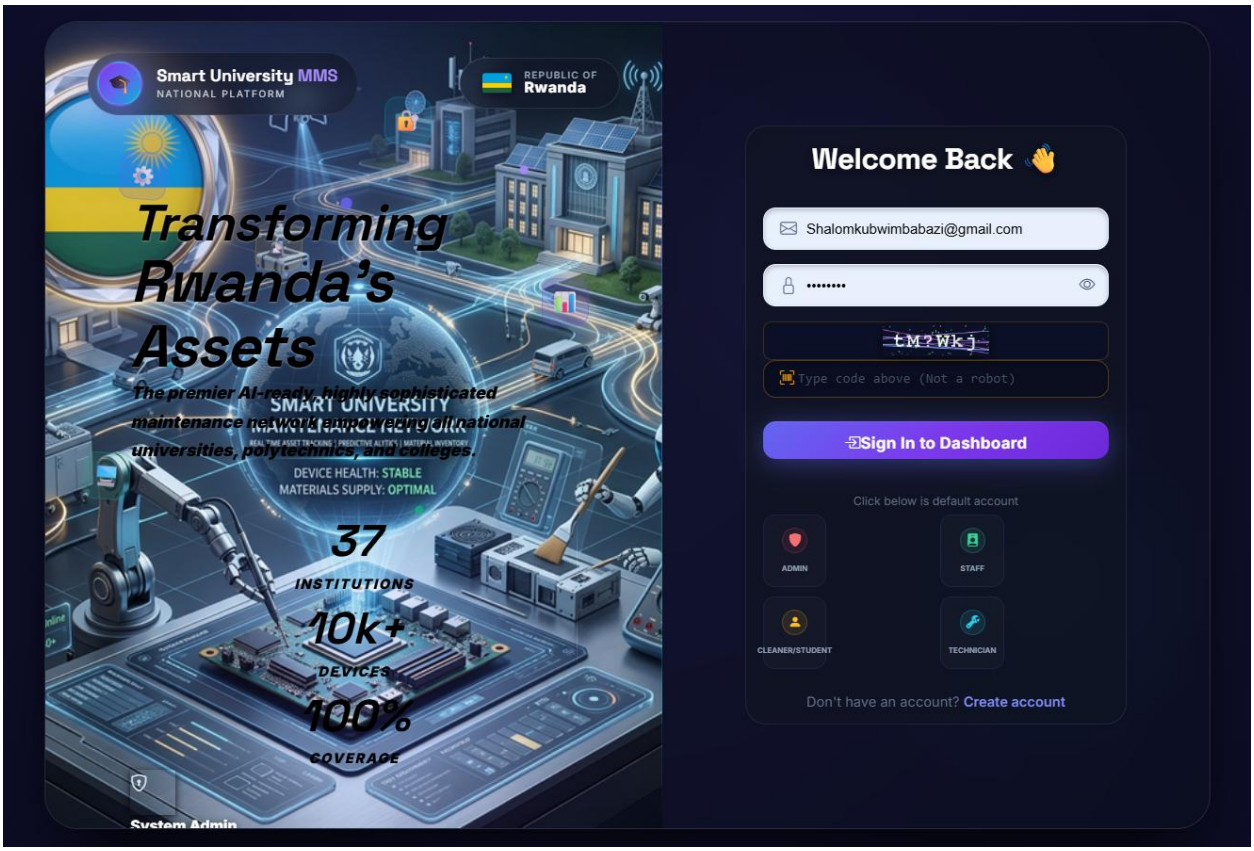
2.4 Account Management

- Multi-step registration process
- Account status flow:
  PENDING_EMAIL → PENDING_APPROVAL → ACTIVE
- Admin approval for user activation
- Password reset system (planned)

3. TECHNICAL IMPLEMENTATION DETAILS

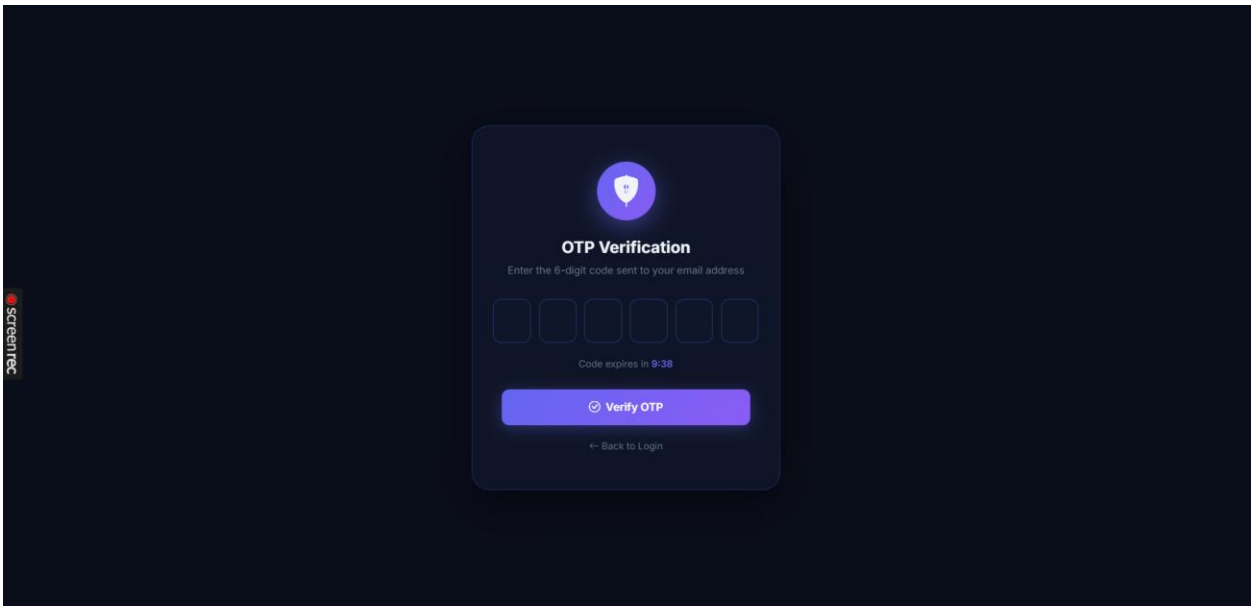
3.1 JWT Token Generation (Java)

```
public String generateToken(User user) {
    return Jwts.builder()
        .setSubject(user.getEmail())
        .claim("role", user.getRole().name())
        .claim("userId", user.getId())
        .setIssuedAt(new Date())
        .setExpiration(new Date(System.currentTimeMillis() + 86400000))
        .signWith(SignatureAlgorithm.HS512, jwtSecret)
        .compact();
}
```



3.2 OTP Generation

```
public String generateOtp() {
    Random random = new Random();
    return String.format("%06d", random.nextInt(1000000));
}
```



4. SECURITY MEASURES IMPLEMENTED

4.1 Authentication Security

- BCrypt password hashing
- JWT expiration (24 hours)
- Secure session management
- CSRF protection

4.2 Data Protection

- Input validation
- SQL injection prevention
- XSS protection
- API rate limiting

4.3 Access Control

- Strict role enforcement
- Secured API endpoints
- Data isolation
- Audit logging